NIST Cybersecurity Framework

Governance, Risk, Controls, and Implementation Template

Joao Luiz D'Andrea

Table of contents

1 Executive Summary **3**

2 Overview **4**
- 2.1 Purpose . . . 4
- 2.2 Objectives . . . 4
- 2.3 Scope . . . 4
  - 2.3.1 In scope . . . 4
  - 2.3.2 Out of scope . . . 4
- 2.4 Intended Audience . . . 5

3 Framework Foundation **5**
- 3.1 Background . . . 5
- 3.2 Core Components . . . 5
- 3.3 Functions . . . 6
  - 3.3.1 Function summary . . . 6
- 3.4 Profiles and Tiers . . . 6
  - 3.4.1 Example profile table . . . 7

4 Governance Model **7**
- 4.1 Governance Objectives . . . 7
- 4.2 Governance Structure . . . 7
  - 4.2.1 Example governance bodies . . . 7
- 4.3 Three Lines Model . . . 7
  - 4.3.1 First line . . . 8
  - 4.3.2 Second line . . . 8
  - 4.3.3 Third line . . . 8

5 Roles and Responsibilities **8**
- 5.1 Key Roles . . . 8

5.2 RACI Matrix 9

6 Policy Framework **10**
6.1 Core Policies 10
6.2 Standards and Procedures 11

7 Core Processes **11**
7.1 Govern 11
7.2 Identify 11
7.3 Protect 11
7.4 Detect 12
7.5 Respond 12
7.6 Recover 12
7.7 Profile Management 13

8 Control Framework **13**
8.1 Control Domains 13
8.1.1 Example control domains 13
8.2 Sample Control Catalogue 13

9 Artefacts and Evidence **14**
9.1 Required Artefacts 14
9.2 Evidence Model 15

10 Architecture and Technology Implications **15**
10.1 Security by Design 15
10.2 Technology Landscape View 16
10.3 Dependency and Data Flow Mapping 16

11 Risk Management **16**
11.1 Cyber Risk Model 16
11.2 Example Risk Categories 16
11.3 Risk Register Template 17

12 Metrics and Reporting **17**
12.1 Key Metrics 17
12.2 Dashboard Structure 17

13 Audit and Assurance **18**
13.1 Assurance Model 18
13.2 Testing Themes 18

14 Implementation Roadmap **18**
14.1 Maturity Phases . . . 18
14.1.1 Phase 1: Foundation . . . 18
14.1.2 Phase 2: Control Design . . . 19
14.1.3 Phase 3: Integration . . . 19
14.1.4 Phase 4: Optimisation . . . 19
14.2 Roadmap Table . . . 19

15 Cross-Framework Integration **19**
15.1 Relationship to Other Frameworks . . . 19
15.2 Example Mapping Themes . . . 20

16 Maturity Model **20**
16.1 Suggested Maturity Levels . . . 20
16.1.1 Level 1: Initial . . . 20
16.1.2 Level 2: Repeatable . . . 20
16.1.3 Level 3: Defined . . . 20
16.1.4 Level 4: Managed . . . 21
16.1.5 Level 5: Optimised . . . 21
16.2 Assessment Dimensions . . . 21

17 Practical Templates **21**
17.1 Suggested Appendices . . . 21

18 Customisation Notes **22**

19 References **22**

1 Executive Summary

The NIST Cybersecurity Framework (CSF) provides a flexible, outcome-based structure for managing cybersecurity risk across organisations of different sizes, sectors, and levels of maturity. This document provides a practical template for defining the organisation's cybersecurity governance model, risk management approach, control structure, implementation roadmap, and assurance model using NIST CSF 2.0.

This template can be used to document the organisation's target operating model for cybersecurity, align business and technology stakeholders, support risk-based investment decisions, and integrate cybersecurity with enterprise governance, resilience, compliance, and assurance processes.

2 Overview

2.1 Purpose

This document provides a practical template for defining, implementing, operating, and assuring a cybersecurity management system aligned to the NIST Cybersecurity Framework.

2.2 Objectives

The main objectives of applying the NIST Cybersecurity Framework are to:

- establish a common language for cybersecurity risk
- align cybersecurity with business objectives and enterprise risk
- define and prioritise cybersecurity outcomes
- improve governance, resilience, and incident readiness
- strengthen communication across executives, business units, risk teams, and technical teams
- support continuous improvement through profiles, tiers, metrics, and assurance

2.3 Scope

Describe the scope of NIST CSF applicability in the organisation.

2.3.1 In scope

- enterprise cybersecurity governance
- business services and critical processes
- information assets and data
- applications, platforms, infrastructure, and cloud services
- operational technology where applicable
- third-party services and supply chain dependencies
- cyber resilience, incident response, and recovery arrangements

2.3.2 Out of scope

Document justified exclusions, if any.

2.4 Intended Audience

- Board and executive leadership
- Chief Information Security Officer
- Chief Information Officer
- Enterprise Risk Management teams
- Security architecture and engineering teams
- IT operations and service management teams
- Business owners and control owners
- Compliance and legal teams
- Internal audit and assurance teams
- PMO / transformation teams

3 Framework Foundation

3.1 Background

The NIST Cybersecurity Framework is designed to help organisations understand, assess, prioritise, and communicate cybersecurity risks. CSF 2.0 is intended for use by any organisation and is structured around six Functions: Govern, Identify, Protect, Detect, Respond, and Recover.

3.2 Core Components

The framework is built around the following components:

- Functions
- Categories
- Subcategories
- Organisational Profiles
- Implementation Tiers

Profiles support comparison between current and target cybersecurity outcomes, and Tiers help characterise how rigorously cybersecurity risk governance and management practices are applied.

3.3 Functions

Document how the organisation applies the six CSF Functions:

- Govern
- Identify
- Protect
- Detect
- Respond
- Recover

3.3.1 Function summary

Function	Purpose
Govern	Establish, communicate, and monitor cybersecurity risk management strategy, expectations, and oversight
Identify	Understand assets, business context, and cybersecurity risks
Protect	Safeguard assets and reduce the likelihood or impact of incidents
Detect	Discover and analyse anomalous events and cybersecurity incidents
Respond	Contain, manage, and communicate during cybersecurity incidents
Recover	Restore capabilities and services and improve resilience after incidents

3.4 Profiles and Tiers

Describe how the organisation will use:

- Current Profile
- Target Profile
- gap analysis
- prioritised improvement roadmap
- Implementation Tiers

3.4.1 Example profile table

CSF Area	Current State	Target State	Gap	Priority	Owner
Governance	Example	Example	Example	High	Example

4 Governance Model

4.1 Governance Objectives

Define the governance objectives for NIST CSF adoption:

- establish executive accountability for cybersecurity risk
- align cybersecurity priorities with enterprise strategy and risk appetite
- assign ownership for CSF outcomes
- embed governance into investment, change, operations, and resilience processes
- maintain evidence of implementation and control effectiveness
- support continuous improvement through profiles, metrics, and assurance

4.2 Governance Structure

Describe the governance bodies and their responsibilities.

4.2.1 Example governance bodies

- Board / Risk Committee
- Executive Cybersecurity Steering Committee
- Information Security Forum
- Enterprise Risk Committee
- Architecture Review Board
- Operational Resilience Committee
- Internal Audit

4.3 Three Lines Model

Describe responsibilities across the three lines.

4.3.1 First line

- business ownership of services, assets, and operational controls
- technology and security operations
- process execution and evidence production
- incident detection, response, and recovery execution

4.3.2 Second line

- cybersecurity governance
- risk oversight
- policy and standard setting
- compliance monitoring
- challenge and advisory support

4.3.3 Third line

- internal audit
- independent assurance
- control effectiveness review

5 Roles and Responsibilities

5.1 Key Roles

Document the main NIST CSF-related roles.

- Board
- CEO / Executive Management
- Chief Information Security Officer
- Chief Information Officer
- Chief Risk Officer
- Business Service Owner
- Information Asset Owner
- Security Architect
- Security Operations Lead
- Incident Response Lead
- Infrastructure / Platform Owner
- Third-Party Risk Manager
- Business Continuity Lead

- Internal Audit

5.2 RACI Matrix

Use the following model and adapt it.

Activity	Board	Exec	CISO	CIO	Risk	Business Owner	Security Ops	Architecture	Audit
Approve cybersecurity strategy	A	R	C	C	C	I	I	I	I
Maintain current and target profiles	I	A	R	C	C	C	C	C	I
Define cyber risk appetite	A	R	C	C	R	C	I	I	I
Approve security policies and standards	I	A	R	C	C	I	C	C	I
Operate detection and monitoring	I	I	A	C	I	I	R	C	I

Activity	Board	Exec	CISO	CIO	Risk	Business Owner	Security Ops	Architecture	Audit
Manage cyber incidents	I	A	R	C	C	C	R	I	I
Test resilience and recovery	I	A	C	C	C	R	C	C	I
Perform independent assurance	I	I	I	I	I	I	I	I	R/A

6 Policy Framework

6.1 Core Policies

List and describe the main cybersecurity-related policies.

- Cybersecurity Policy
- Information Security Policy
- Risk Management Policy
- Asset Management Standard
- Identity and Access Management Policy
- Vulnerability Management Standard
- Logging and Monitoring Standard
- Incident Response Policy
- Business Continuity / Disaster Recovery Policy
- Third-Party Security Policy
- Secure Development Policy
- Data Protection and Classification Policy

6.2 Standards and Procedures

Document the standards, baselines, procedures, and playbooks supporting implementation.

7 Core Processes

7.1 Govern

Describe how the organisation establishes cybersecurity strategy, policy, oversight, risk tolerance, roles, supply chain governance, and performance monitoring. CSF 2.0 introduced **Govern** as a distinct Function to strengthen governance and enterprise alignment. :contentReferenceoaicite:3

7.2 Identify

Describe the processes for:

- asset inventory
- business context analysis
- dependency mapping
- critical service identification
- risk assessment
- threat and vulnerability understanding

7.3 Protect

Describe the processes for:

- access control
- awareness and training
- data protection
- platform and infrastructure hardening
- secure configuration
- maintenance
- protective technology
- secure development and change management

7.4 Detect

Describe the processes for:

- continuous monitoring
- telemetry and log collection
- alerting
- anomaly detection
- detection engineering
- threat intelligence integration
- triage and escalation

7.5 Respond

Describe the processes for:

- incident triage
- containment
- eradication
- internal and external communications
- stakeholder coordination
- regulatory notification where required
- lessons learned

NIST's incident response guidance aligns incident response activities with the CSF 2.0 functions and lifecycle. :contentReferenceoaicite:4

7.6 Recover

Describe the processes for:

- restoration of services
- recovery prioritisation
- validation and assurance
- resilience testing
- crisis communications
- recovery lessons learned
- improvement planning

7.7 Profile Management

Document how the organisation creates and maintains:

- Current Profile
- Target Profile
- gap analysis
- remediation plan
- prioritised initiatives
- review cycle

NIST provides profile templates and guidance for using organisational profiles. :contentReferenceoaicite:5

8 Control Framework

8.1 Control Domains

Organise the control environment using the six CSF Functions.

8.1.1 Example control domains

- governance and oversight
- risk management
- asset management
- identity and access management
- awareness and training
- data security
- platform security
- monitoring and detection
- incident response
- recovery and resilience
- third-party and supply chain security
- continuous improvement

8.2 Sample Control Catalogue

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
NIST-01	Cybersecurity strategy approved	Ensure executive direction and accountability	CISO	Annual	Approved strategy
NIST-02	Current and target profiles maintained	Drive risk-based improvement	Cyber Governance Lead	Semi-annual	Profile register
NIST-03	Asset inventory maintained	Ensure visibility of assets and services	IT Operations	Monthly	Asset register
NIST-04	Security monitoring performed	Detect suspicious events in a timely manner	SOC Manager	Continuous	SIEM reports
NIST-05	Incident response exercised	Improve response readiness	Incident Manager	Quarterly	Exercise reports
NIST-06	Recovery capabilities tested	Validate resilience and restoration	Continuity Lead	Annual	Recovery test evidence

9 Artefacts and Evidence

9.1 Required Artefacts

Document the key artefacts used to support implementation and assurance.

- cybersecurity strategy
- cyber risk appetite statement
- policy set and control standards
- asset inventory
- dependency map
- business impact analysis
- current and target profiles

- risk register
- threat scenarios
- vulnerability management records
- detection use case catalogue
- incident response plan
- incident playbooks
- recovery plans
- resilience test reports
- third-party security assessments
- metrics and dashboard packs
- audit reports

9.2 Evidence Model

For each artefact define:

- owner
- purpose
- location
- frequency of update
- retention period
- assurance mechanism

10 Architecture and Technology Implications

10.1 Security by Design

Describe how cybersecurity requirements are embedded into:

- enterprise architecture
- solution design
- cloud architecture
- network design
- identity architecture
- endpoint and platform engineering
- data architecture
- software delivery pipelines
- third-party integration patterns

10.2 Technology Landscape View

Document the security-relevant architecture elements:

- business services and critical processes
- application and data estate
- infrastructure and cloud platforms
- security tooling landscape
- identity and access ecosystem
- logging and monitoring architecture
- resilience and recovery architecture

10.3 Dependency and Data Flow Mapping

Include or reference:

- business service maps
- application dependency diagrams
- network and trust zone diagrams
- third-party dependency maps
- crown jewel asset maps
- recovery dependency maps

11 Risk Management

11.1 Cyber Risk Model

Describe how cyber risks are identified, assessed, treated, accepted, escalated, and monitored.

11.2 Example Risk Categories

- governance weakness
- incomplete asset visibility
- identity compromise
- unpatched vulnerabilities
- supply chain exposure
- insufficient monitoring coverage
- weak incident coordination
- inadequate resilience and recovery
- insecure change and development practices
- poor evidence and assurance

11.3 Risk Register Template

Risk ID	Risk Description	Cause	Impact	Likelihood	Inherent Risk	Control Strength	Residual Risk	Owner
CY-01	Example	Example	Example	Medium	High	Medium	Medium	Example

12 Metrics and Reporting

12.1 Key Metrics

Examples of cybersecurity metrics:

- percentage of critical assets identified
- percentage of assets covered by monitoring
- percentage of systems compliant with baseline configuration
- vulnerability remediation performance
- identity and privileged access review completion
- mean time to detect
- mean time to contain
- mean time to recover
- number of severe incidents
- percentage of critical third parties assessed
- percentage of recovery tests passed
- percentage of target profile outcomes achieved

12.2 Dashboard Structure

Suggested dashboard views:

- executive cyber risk dashboard
- operational security dashboard
- vulnerability and exposure dashboard
- incident and response dashboard
- resilience and recovery dashboard
- third-party cyber risk dashboard

13 Audit and Assurance

13.1 Assurance Model

Document the assurance approach across:

- management self-assessment
- profile review and gap validation
- second-line control testing
- technical validation and exercises
- internal audit
- external assurance where applicable

13.2 Testing Themes

- governance and policy effectiveness
- asset coverage and visibility
- control design and operating effectiveness
- detection capability
- incident readiness
- recovery readiness
- third-party assurance
- metrics quality and reporting discipline

14 Implementation Roadmap

14.1 Maturity Phases

14.1.1 Phase 1: Foundation

- establish governance and executive sponsorship
- define policy framework
- identify critical services and assets
- create initial current profile
- establish cyber risk register

14.1.2 Phase 2: Control Design

- define target profile
- prioritise control improvements
- strengthen identity, monitoring, vulnerability, and response capabilities
- define resilience and recovery expectations

14.1.3 Phase 3: Integration

- integrate cyber governance with enterprise risk and architecture
- align security operations with business service priorities
- embed third-party and supply chain controls
- improve playbooks, exercises, and evidence management

14.1.4 Phase 4: Optimisation

- refine metrics and dashboards
- automate control evidence
- strengthen profile-based planning
- expand resilience testing and assurance
- drive continuous improvement

14.2 Roadmap Table

Initiative	Description	Owner	Priority	Timeline	Dependency	Status
Example	Example	Example	High	Q1-Q2	Example	Planned

15 Cross-Framework Integration

15.1 Relationship to Other Frameworks

Describe how NIST CSF integrates with:

- ISO/IEC 27001
- NIS2
- DORA
- GDPR

- AI Act
- COBIT
- ITIL
- TOGAF
- enterprise risk management
- business continuity and operational resilience

15.2 Example Mapping Themes

NIST CSF Theme	Related Framework	Integration Point
Govern	COBIT	Governance objectives and accountability
Risk management	ISO 27001	ISMS and risk treatment
Detect / Respond / Recover	NIS2 / DORA	Incident management and resilience
Service resilience	ITIL	Service continuity and operations
Security architecture	TOGAF	Architecture governance and security viewpoints

16 Maturity Model

16.1 Suggested Maturity Levels

16.1.1 Level 1: Initial

Cybersecurity activities are reactive, fragmented, and poorly governed.

16.1.2 Level 2: Repeatable

Basic practices exist but are inconsistently applied across the enterprise.

16.1.3 Level 3: Defined

Profiles, roles, controls, and processes are documented and broadly implemented.

16.1.4 Level 4: Managed

Cybersecurity activities are measured, risk-based, and regularly reviewed by leadership.

16.1.5 Level 5: Optimised

Cybersecurity is integrated into enterprise governance, architecture, operations, and resilience with continuous improvement and strong evidence.

16.2 Assessment Dimensions

- governance
- asset visibility
- protection capability
- detection capability
- incident response
- recovery readiness
- third-party assurance
- metrics and reporting
- control assurance
- improvement discipline

17 Practical Templates

17.1 Suggested Appendices

- Appendix A: Current Profile template
- Appendix B: Target Profile template
- Appendix C: Gap assessment template
- Appendix D: Cyber risk register
- Appendix E: Cybersecurity control catalogue
- Appendix F: Incident playbook template
- Appendix G: Recovery exercise template
- Appendix H: NIST CSF RACI matrix

18 Customisation Notes

This template should be tailored to reflect:

- organisational structure
- sector and regulatory environment
- critical business services
- threat landscape
- sourcing and third-party model
- cloud and technology estate
- maturity level
- assurance expectations
- operating model and budget constraints

19 References

Add authoritative references here, for example:

- NIST Cybersecurity Framework 2.0
- NIST SP 1299 Resource and Overview Guide
- NIST CSF Profiles guidance
- NIST CSF Tiers guidance
- NIST incident response guidance
- internal cybersecurity policies and standards
- enterprise risk framework
- architecture and resilience standards